

Cybersecurity

Introduction to Firewalls and Network Security

Lesson 12.1



Learning Objectives

By the end of today's lesson, you will be able to:

- 1 Explain how open ports contribute to a computer's attack surface.
- 2 Use firewalls to protect a computer's open ports.
- 3 Describe various types of firewalls and their use cases.
- 4 Explain the role firewalls play within a layered defense.
- 5 Gain hands-on experience with developing and implementing firewall policies using UFW and firewalld.



Welcome



Let's Recap

In the Last Module:

We learned how cryptographic tools help maintain the **confidentiality**, **integrity**, and **availability** of data at rest and in transit.



Limits of Cryptography

Suppose a malicious actor attempted to hack into a hospital's web server to perform a ransomware attack.

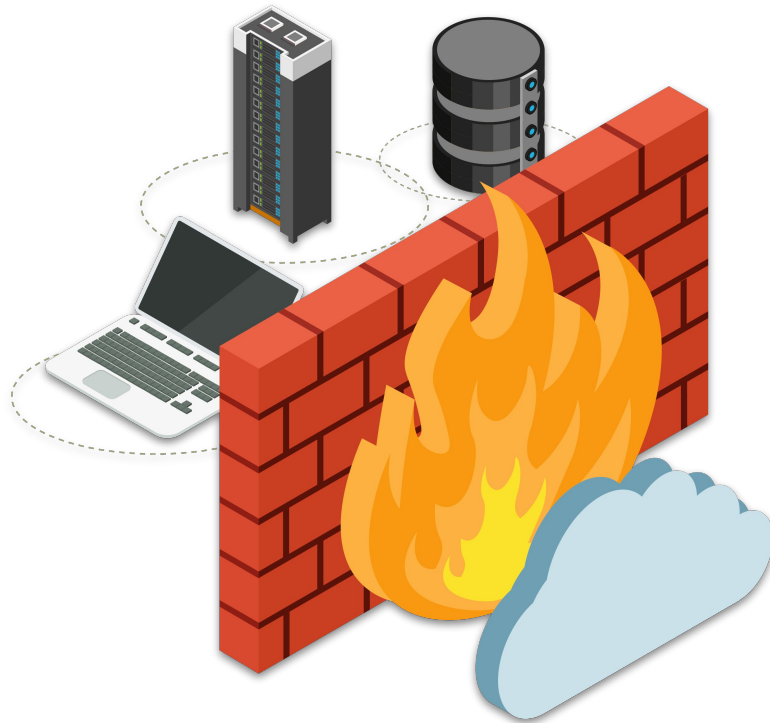
- To keep the private health information of its patients secure, the hospital protects secured access to its website using a cryptographic RSA VPN connection.
- While these tools are important, cryptography is only one part of a multifaceted network defense ecosystem that protects private information and critical network infrastructure.

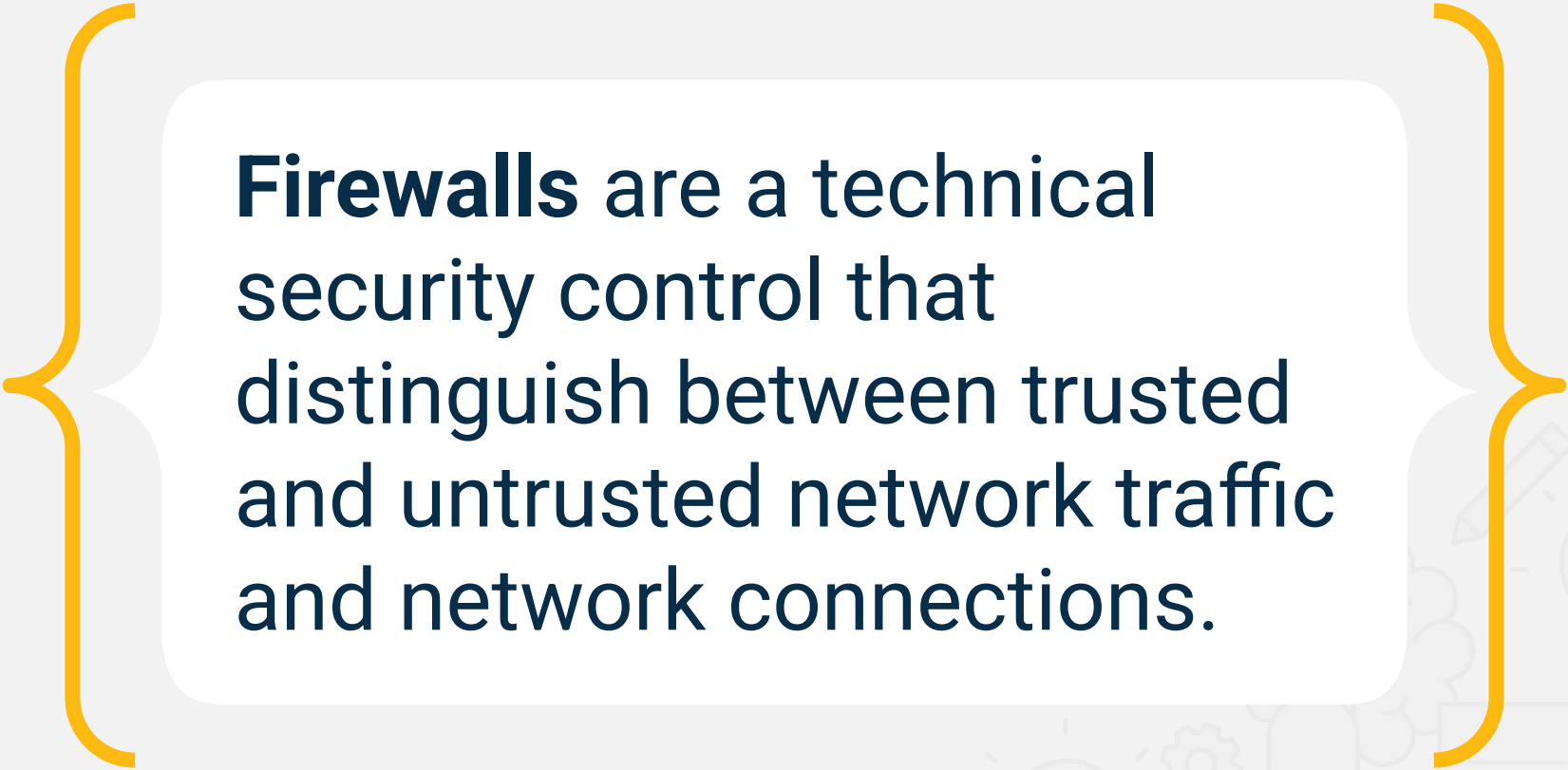


The Need for Network Security

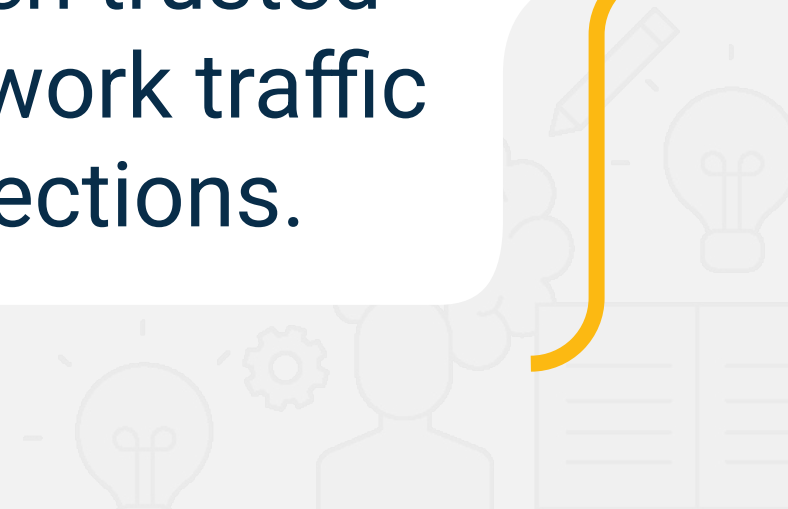
While cryptographic applications help protect private data, other aspects of website security remain at risk.

- Suppose a website is the target of a denial of service (DoS) attack. **Cryptography defenses** aren't much use.
- Therefore, security practitioners need to implement network security strategies like **firewalls** that provide an additional layer of defense.





Firewalls are a technical security control that distinguish between trusted and untrusted network traffic and network connections.





—SANS Institute

"Network security is the process of taking physical- and software-preventative measures to protect the underlying networking infrastructure from unauthorized access, misuse, malfunction, modification, destruction, or improper disclosure, thereby creating a secure platform for computers, users, and programs to perform their permitted critical functions within a secure environment."

Firewalls are the **first line of defense** on the perimeter of the network's edge.

However, they are merely the **first layer** upon which other preventive and **protective layers** are built.



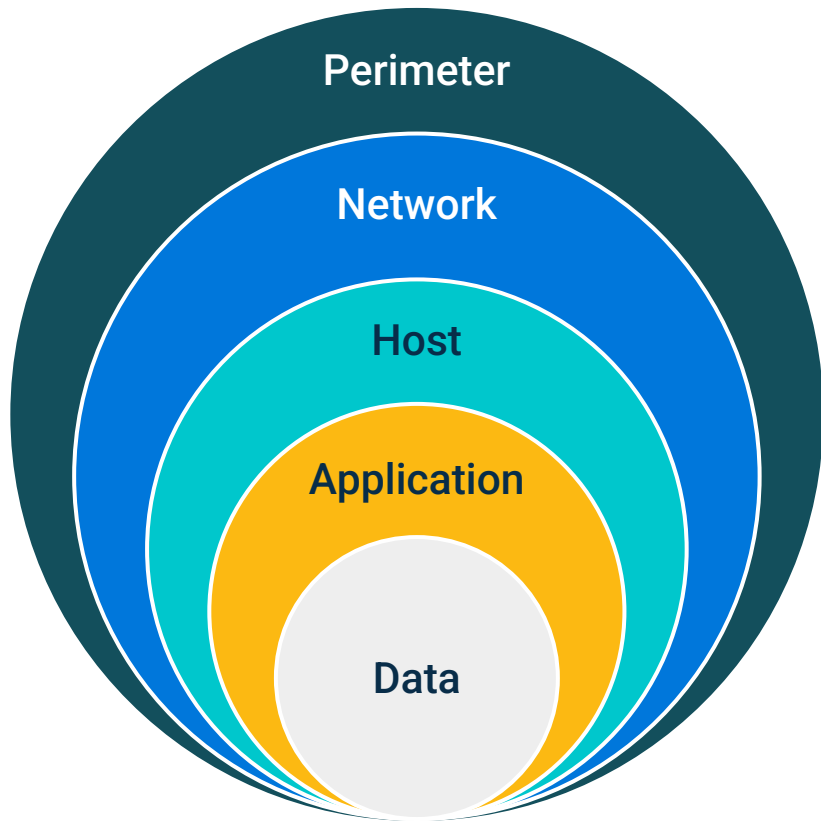


Defense in **Depth**



Defense in Depth

Defense in depth (DiD) plays a critical role in securing organizations.



DiD Mindset

We will apply DiD throughout the module to layer security measures.

Slowing an attack's progression gives **network defenders** time to respond.



Defense in Depth

DiD plays a critical role in securing organizations.

Benefits and limitations
of various types of firewalls.

Today

Intrusion-detection systems (**IDS**) and
network-security monitoring (**NSM**).

Day 2

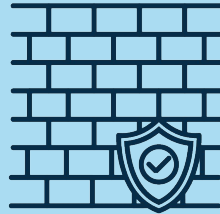
Day 3

Advanced cyber-threat
hunting using enterprise
security management (**ESM**).

Professional Application

Knowledge of computer networking is essential for the following technical roles:

Help Desk or IT Specialist	Entry level IT roles focus more on troubleshooting user issues than implementing network controls.
System or Network Administrator	These roles often determine who is allowed to access devices on a network. They must develop firewall policies and implement them using tools like UFW or firewalld.
SOC Analyst	SOC analysts perform threat hunting and alert triage.
Penetration Tester	Penetration testers must know if a firewall is between them and their target as well as which rules are enabled in order to launch a successful attack against a network.



Firewall Architectures

Ports Recap

Networks allow computers to communicate with one another by sending data to and from open ports on other machines.

Devices must expose open ports in order to communicate with other machines on the network.

- We can't assume that the only people who will connect to a device are those we trust.
- Malicious actors exploit this assumption to access sensitive information.
- Restricting access to open ports is a fundamental skill for any technical security specialist.





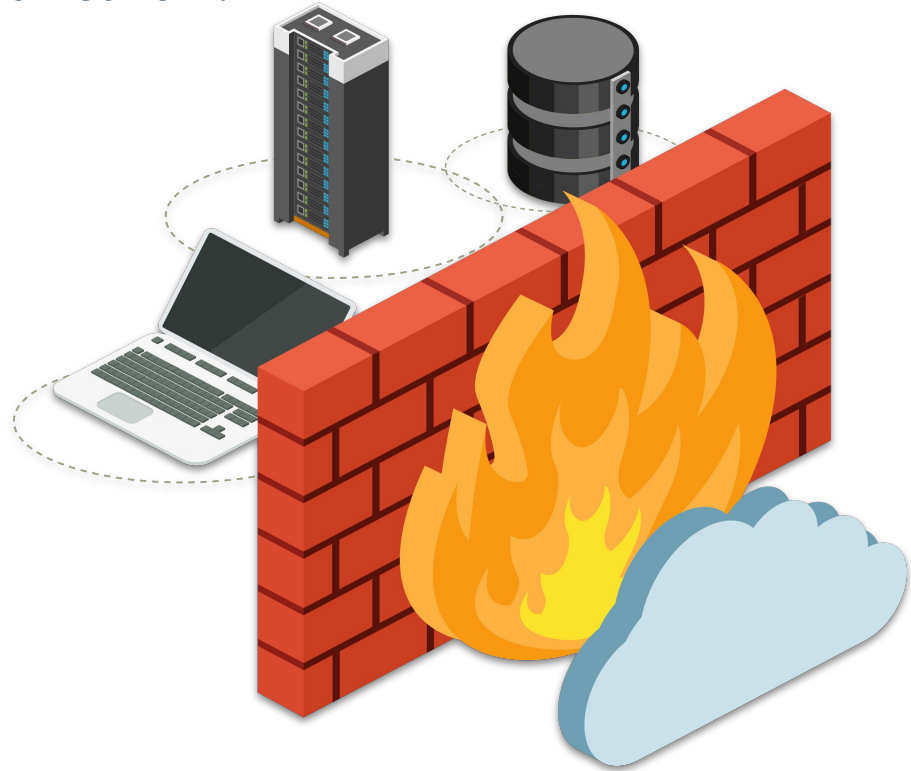
Let's see how we can
secure network ports to
only allow in trusted traffic.

Firewall Architecture

Firewalls provide a layer of protection by analyzing data leaving and entering a network.

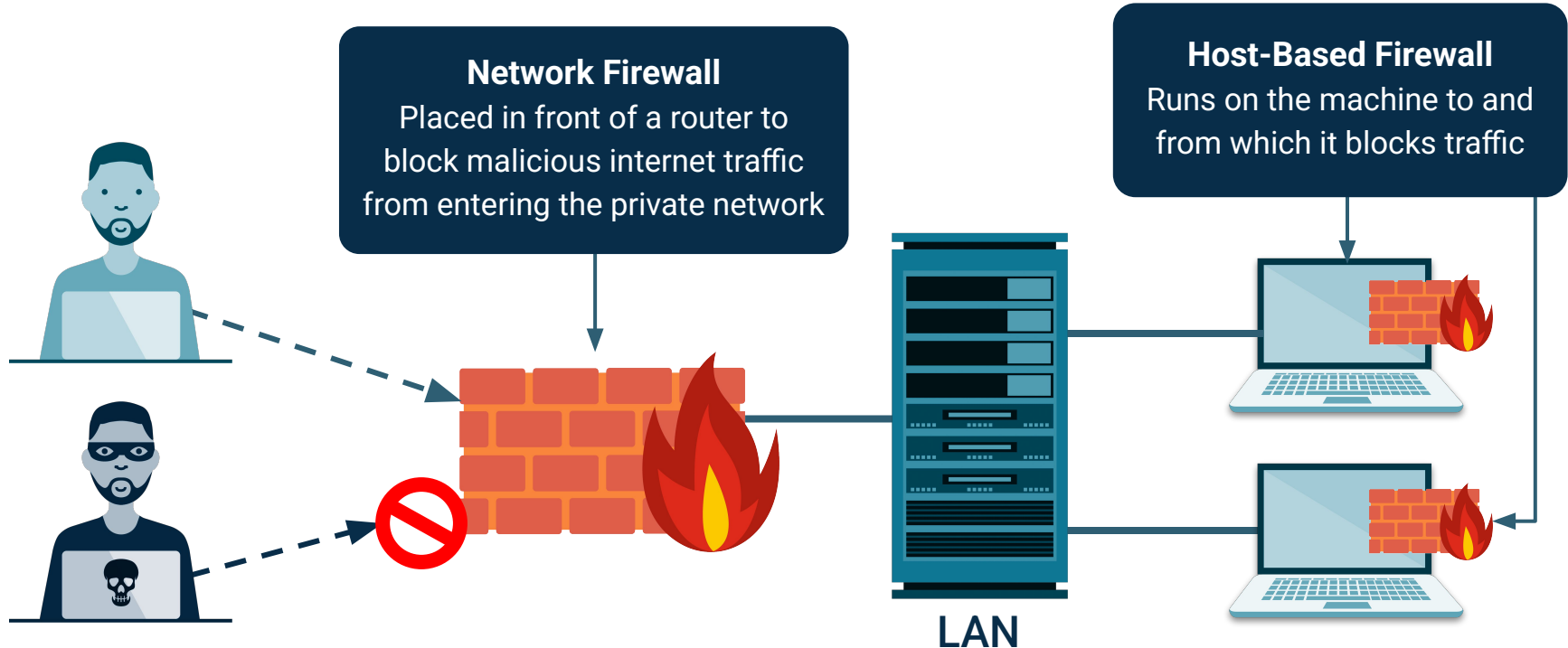
Firewalls are placed between application servers and routers to provide access control.

They protect trusted networks by isolating them from untrusted networks, such as the internet.



Firewalls

Firewalls can be used to either control access to an entire network (**network firewall**) or a single host (**host-based firewall**).



Firewalls

Network and host-based firewalls work in the same way:

01

Intercept traffic before it reaches its target host or router.

02

Inspect the source and destination address and ports, TCP flags, and other features of the incoming packets.

03

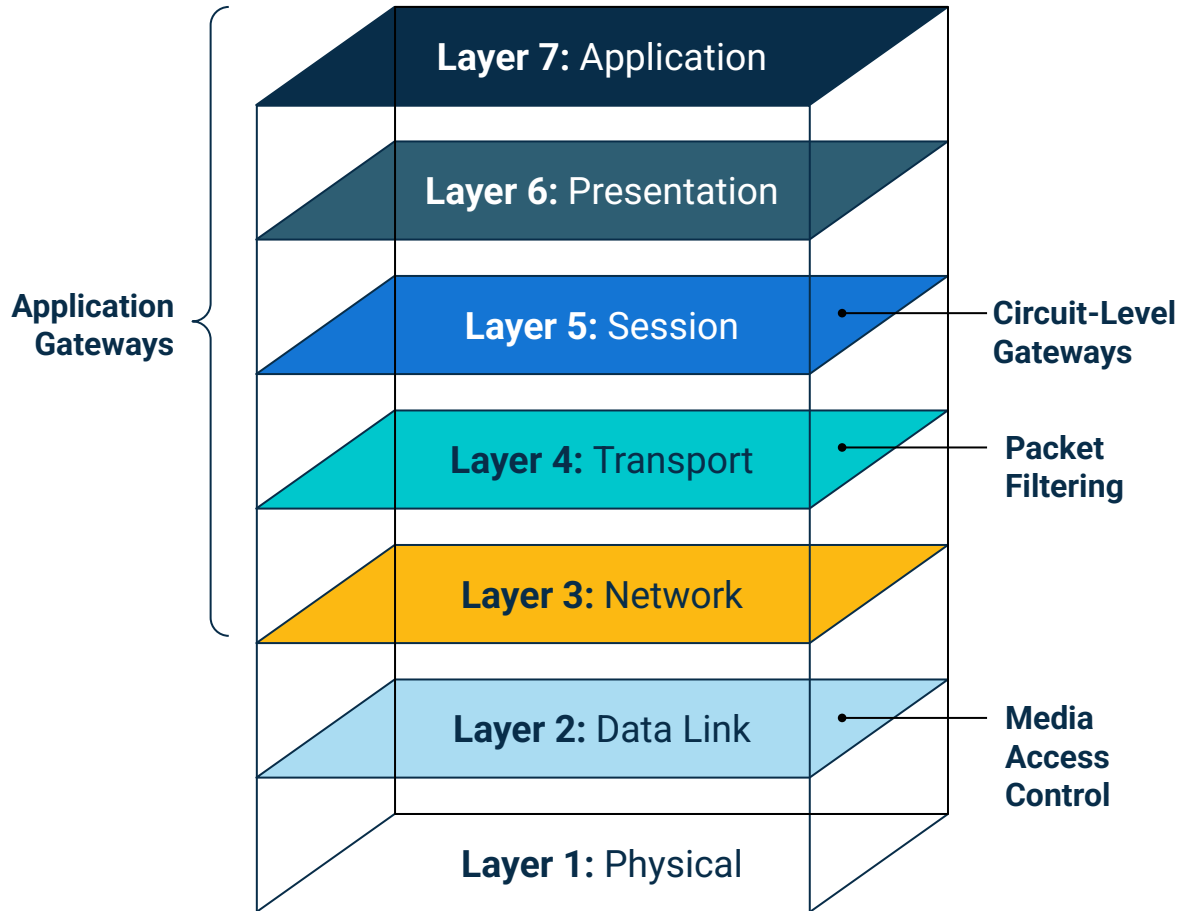
Allow packets that come from trusted sources and deny packets that don't.

Firewalls on the OSI

Firewalls operate at multiple layers of the OSI model.

Four basic types

- Application gateways
- Circuit-level gateways
- Packet filtering (stateless and stateful)
- Media access control (MAC)





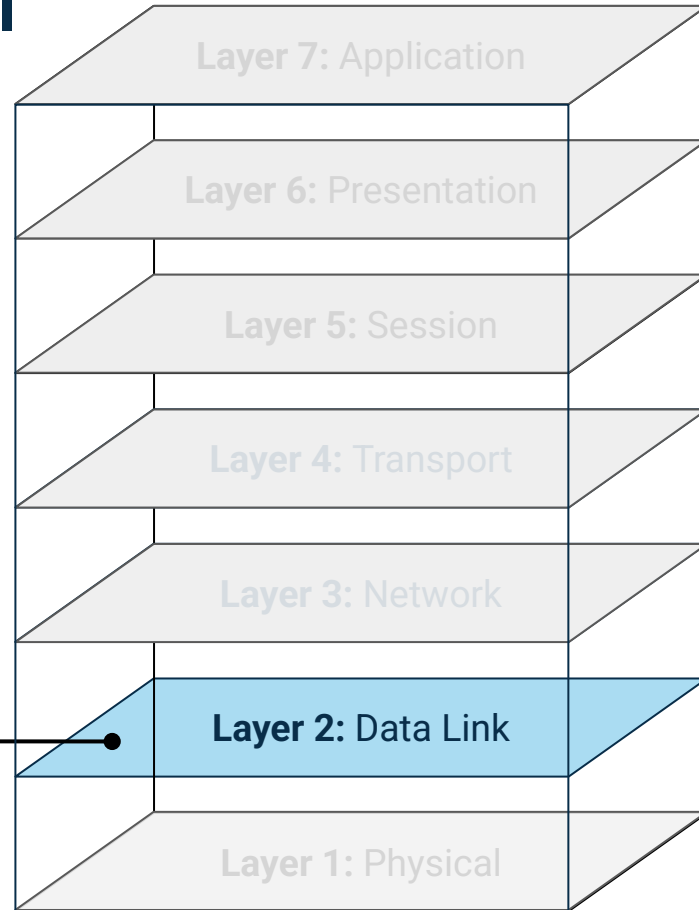
Does anyone remember
what a **MAC address** is?

MAC-Layer Filtering Firewall



The MAC address is a unique hardware ID that helps devices communicate with one another.

MAC firewalls operate at **Layer 2** of the OSI model and filter based on source and destination MAC addresses.



MAC-Layer Filtering Firewall

Routers compare the MAC address of a device against an approved list. If there is a match, the traffic is forwarded to that device.



Advantage

- Can secure the network from novice attackers



Disadvantage

- Can be easily bypassed by MAC spoofing

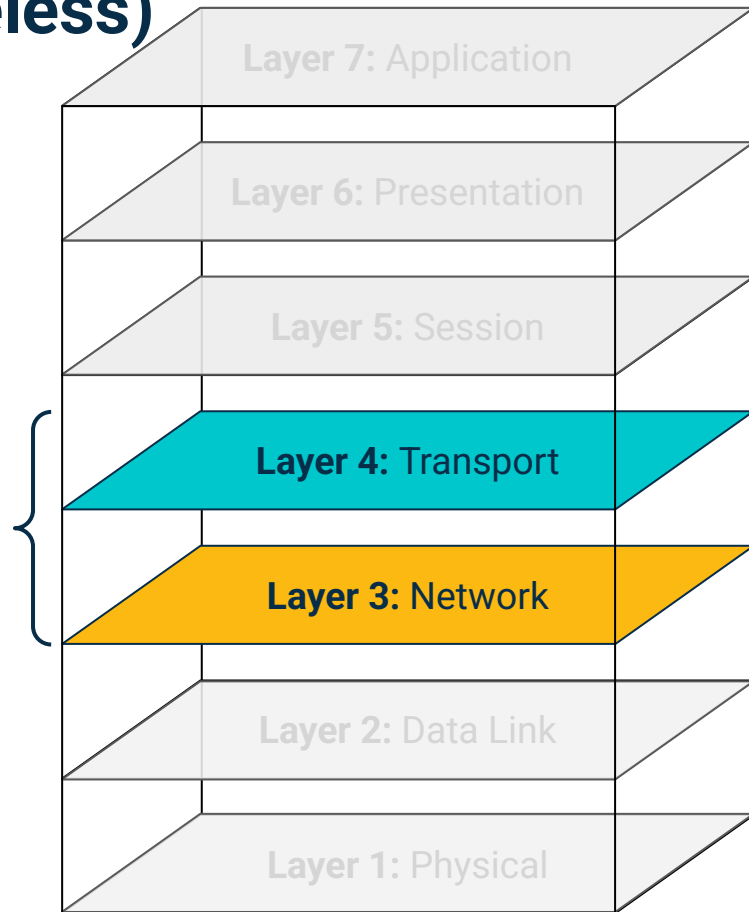
Packet-Filtering Firewalls (Stateless)

Stateless packet-filtering firewalls operate at **Layer 3** and **Layer 4** of the OSI model.

These firewalls statistically evaluate the contents of packets and do not keep track of the state of a network connection (a.k.a. stateless).

Use rules based on individual packets

- Source and destination IP address
- Source and destination port information
- IP protocols
- Ingress and egress interface



Packet-filtering Firewalls (Stateless)

Stateless packet-filtering firewalls create checkpoints within a router and examine packets as they progress through an interface. If the information does not pass the inspection, it is dropped.



Advantages

- Not resource-intensive, meaning they are low cost and do not have a significant impact on system performance
- Work best with small networks



Disadvantages

- Easy to subvert compared to more robust firewalls
- Only operate at the network layer
- Vulnerable to spoofing and do not support custom-based rule sets

Packet-Filtering Firewalls (Stateful)

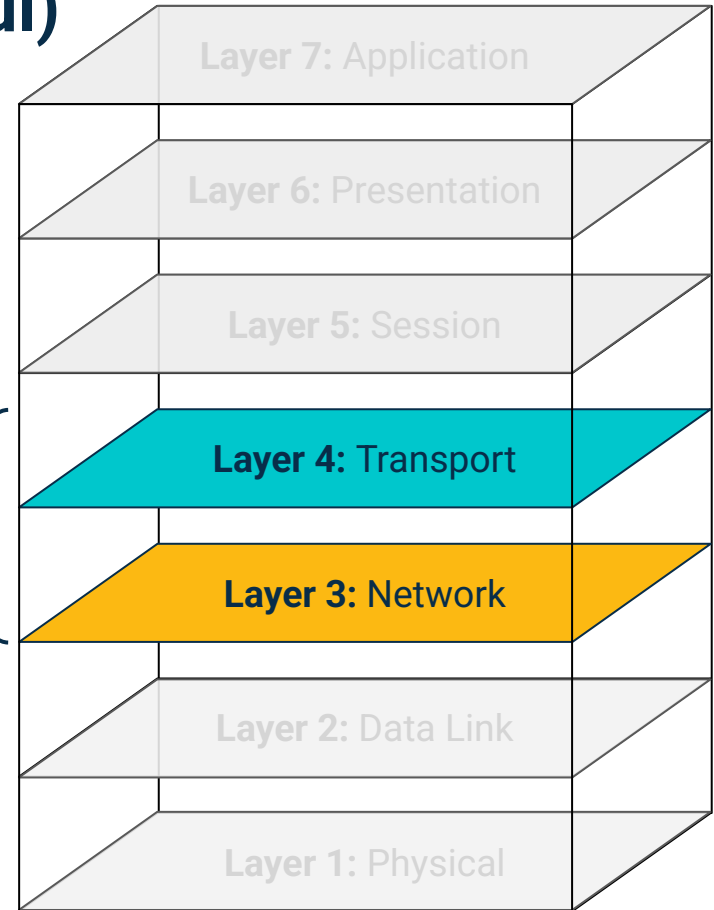
Stateful packet-filtering firewalls operate at **Layer 3** and **Layer 4** of the OSI model.

Stateful firewalls can determine if a packet is:

- Trying to establish a new connection, known as a new state
- Part of an existing connection, known as an established state
- Is neither a new nor an existing connection, known as a rogue packet

Rather than look at individual packets, stateful firewalls examine the connection as whole, looking at streams of packets.

They inspect the packets' conversation and routing tables and use a combination of TCP handshake verification and packet-inspection technology.



Packet-Filtering Firewalls (Stateful)

Since stateful firewalls understand the context of the entire data stream, they can determine which application layer protocols are in use.

However, they cannot actually understand application layer protocols, and therefore can't determine what the underlying traffic is doing. While they can identify that a connection is using HTTP, they cannot identify if the connection is being used to request an HTML file or a PNG image.



Advantage

- Offer transparent mode, which allows direct connections between clients and servers



Disadvantage

- Are resource-intensive systems

Circuit-Level Firewalls

Circuit-level firewalls operate at **Layer 5** of the OSI model.

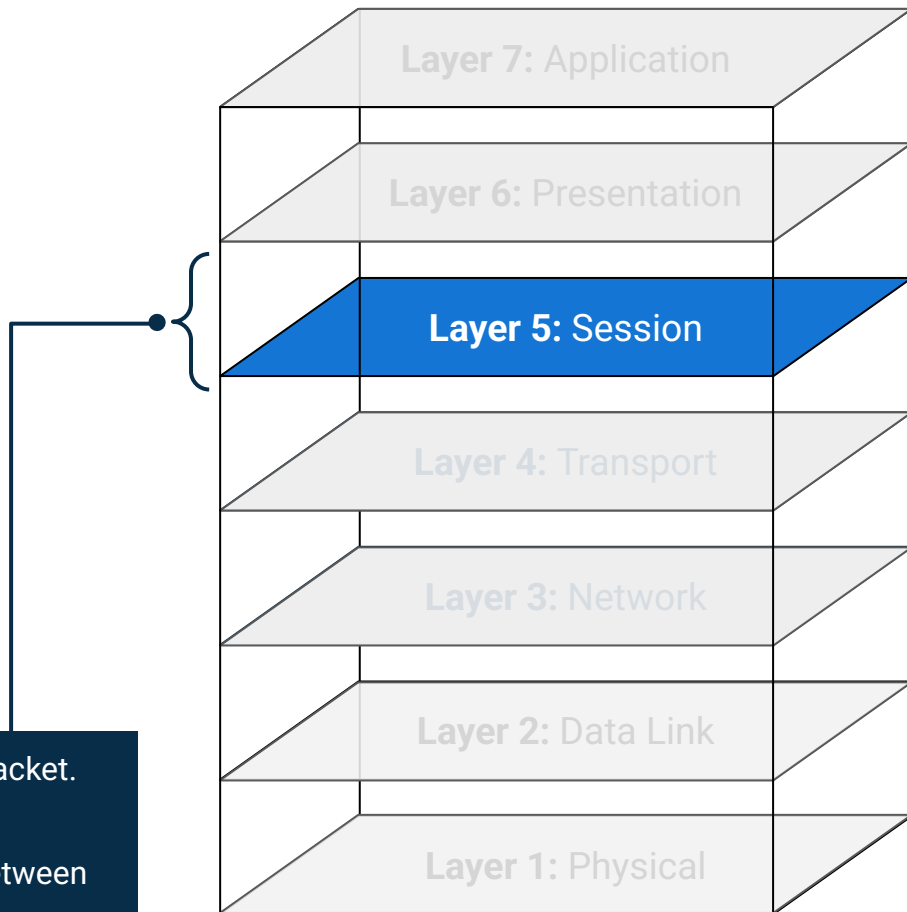
Circuit-level gateways work by verifying the three-way TCP handshake.

TCP handshake checks can verify the following about a source:

- Unique session identifier (SID)
- State of the connection (handshake established, closed)
- Sequencing information

These firewalls only look at the header of a packet.

Once the circuit is allowed to establish an end-to-end connection, all data is tunneled between parties.



Circuit-Level Firewalls

By verifying the three-way TCP handshake, circuit-level gateways ensure that session packets are from legitimate sources.



Advantages

- Quickly and easily approve and deny traffic without consuming significant computing resources
- Relatively inexpensive and provide anonymity to the private network



Disadvantages

- Do not check the contents of the packet
- If a packet contains malware but has the correct TCP information, the data is allowed to pass through

Application (Proxy) Firewalls

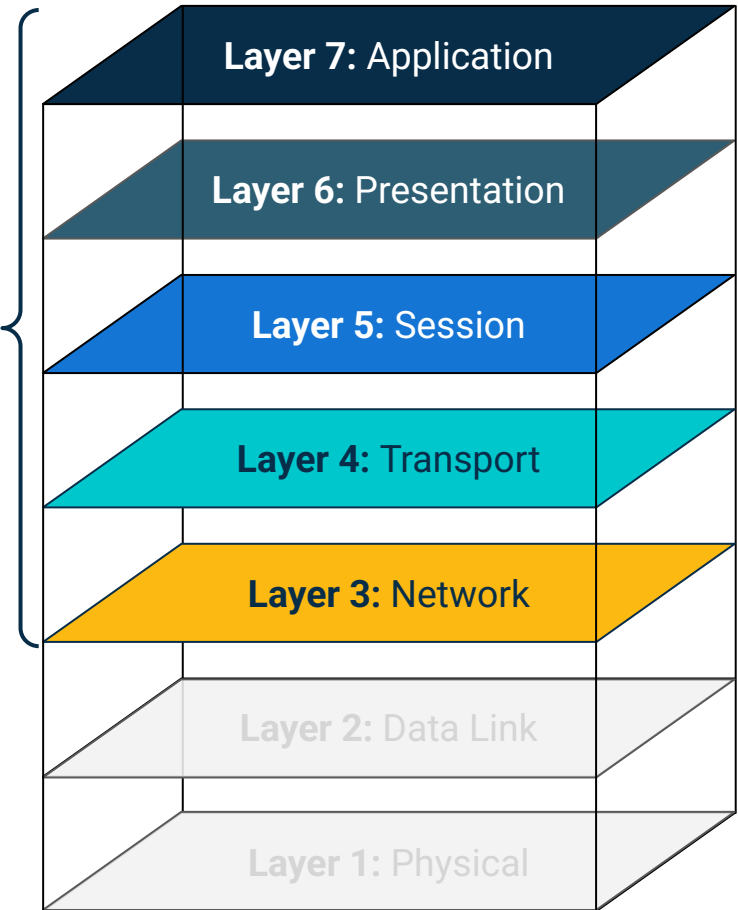
Application or proxy firewalls operate at **Layer 3 through Layer 7** of the OSI model.

They inspect the actual contents of the packet, including authentication and encryption components.

Proxy firewalls use deep packet inspection and stateful inspection to determine if incoming traffic is safe or harmful.

They intercept all traffic on its way to its final destination without the data source knowing.

A connection is established to the proxy firewall, which inspects the traffic and forwards it if it's determined to be safe, or drops it if it's determined to be malicious.



Application Firewalls

Application gateways create an extra layer of protection between the traffic source and its destination behind the network by **obscuring** the destination from the source, creating an additional layer of anonymity and protection for the network.



Advantage

- More secure than other implementations and provide simple log-and-file audit management for incoming traffic



Disadvantages

- Resource-intensive
- Require robust modern hardware and high costs
- Bypassed with encryption

Next-Gen Firewalls (NGFW)

NGFWs operate at **Layer 3 through Layer 7** of the OSI model.

They build on the features found in traditional firewalls and combines features found in other security appliances.

Other features include:

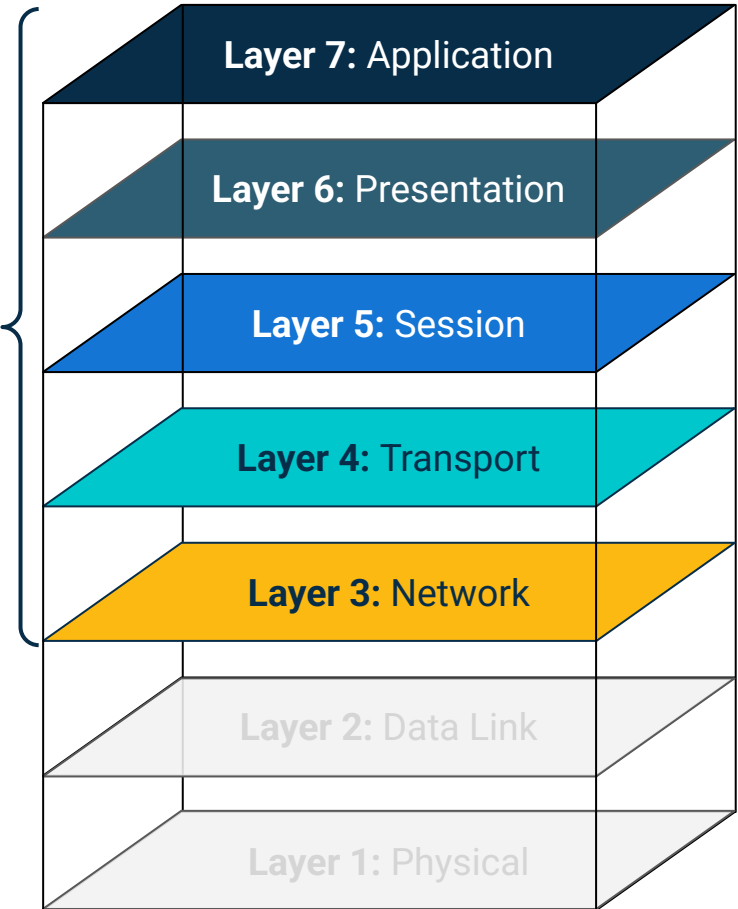
Antivirus

Ransomware

Spam protection

Intrusion prevention system (IPS)

Endpoint security



Next-Gen Firewalls (NGFW)

NGFWs provide protection to company devices that might be outside of the office and guarantee a certain level of compliance for security standards.



Advantage

- Offer increased protection by utilizing security features beyond those found on traditional firewalls



Disadvantages

- Higher cost associated with device

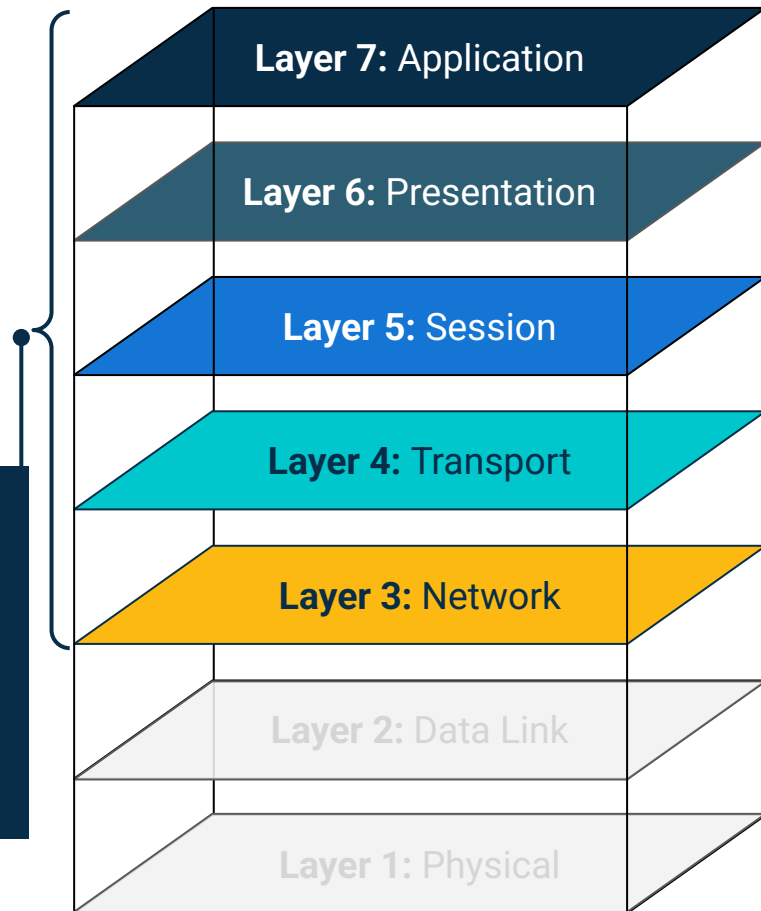
AI-Enhanced Firewalls

A new version of firewall, these incorporate the benefits of NGFWs, but build upon them with **artificial intelligence (AI)**.

AI integration aids in speeding up the process of management and maintenance.

AI Firewall Characteristics:

- Natural language questions
- Detailed summaries on attacks
- Maintenance to remove redundant rules
- Recommendations to configuration



Firewall Summary

- Firewalls are modes of protection provided to an organization or user that analyze data leaving or entering a network.
- Packet-filter firewalls operate between Layers 3 and 4.
- Stateful firewalls operate between Layers 3 and 4.
- Circuit-level firewalls operate at Layer 5.
- Application or proxy firewalls operate at Layers 3 through 7.
- NGFWs provide security features beyond those in traditional firewalls.
- AI firewalls leverage generative AI to improve operation and functionality.



UFW

Uncomplicated Firewall (UFW)

UFW is a multifunctional firewall that provides stateless and stateful packet filtering.



It works on all kinds of network address and port translation, such as network address translation (NAT) and network address protection (NAP).

It is a standard Linux firewall, available by default in the latest Ubuntu installations.

UFW

UFW provides the following features:

Term	Definition
Host-Based	UFW is most commonly used on hosts.
Logging	UFW has the ability to generate multilevel logs, providing great insight into attacks.
Remote Management	Firewalls can be remotely managed. For example, through SSH via port 22.
Rules for Allow/Deny	Examines source and destination IP addresses, port numbers, and packet types, all without opening the packet. Also uses TCP handshake packet inspection.
Rate-Limiting	Supports rate-limited connections to protect from brute force attacks.



Demonstration Scenario



The IT department is hosting a website that requires the use of both normal and encrypted web traffic.

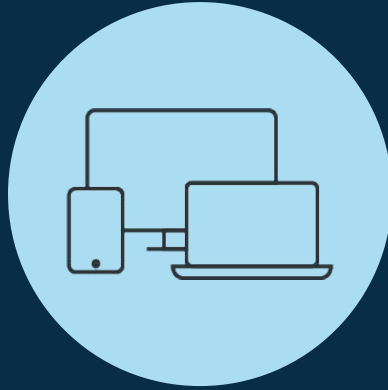
The CISO has released a security advisory authorizing the use of secured remote firewall administration.

We need to **open** ports:

- 22
- 80
- 443

UFW Commands

<code>sudo ufw reset</code>	resets all UFW rules back to factory defaults
<code>sudo ufw status</code>	checks the current status of the firewall
<code>sudo ufw enable</code>	starts the firewall and updates rules
<code>sudo ufw reload</code>	stops and restarts UFW
<code>sudo ufw default deny incoming</code>	blocks all incoming connections
<code>sudo ufw default allow outgoing</code>	allows all outgoing connections
<code>sudo ufw allow</code>	opens specific ports
<code>sudo ufw deny</code>	closes specific ports
<code>sudo ufw delete</code>	deletes rules
<code>sudo ufw disable</code>	shuts down the firewall



Instructor Demonstration

UFW

Recap

<code>sudo ufw reset</code>	resets all UFW rules back to factory defaults
<code>sudo ufw status</code>	checks the current status of the firewall
<code>sudo ufw enable</code>	starts the firewall and updates rules
<code>sudo ufw reload</code>	stops and restarts the UFW
<code>sudo ufw default deny incoming</code>	blocks all incoming connections
<code>sudo ufw default allow outgoing</code>	allows all outgoing connections
<code>sudo ufw allow</code>	opens specific ports
<code>sudo ufw deny</code>	closes specific ports
<code>sudo ufw delete</code>	deletes rules
<code>sudo ufw disable</code>	shuts down the firewall



Activity

Configuring UFW

In this activity, your role will be as an SOC analyst for the large retailer Better Buys, Inc.

- The PCI DSS has 12 requirements with which organizations must comply. The first states that organizations must protect their systems with firewalls.
- You'll configure UFW to ensure that your organization is in compliance with PCI DSS.

Suggested Time
20 minutes



Time's Up!
Let's review

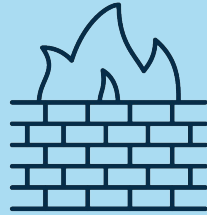


Questions?





Break
15 mins



firewalld

firewalld

UFW and firewalld are very similar, but they do have some distinct differences.

firewalld provides additional features and flexibility, such as:

It is a bit more complicated than UFW, but provides greater control over settings.

It supports zone-based rules, providing different firewall settings for home, office, or public Wi-Fi.

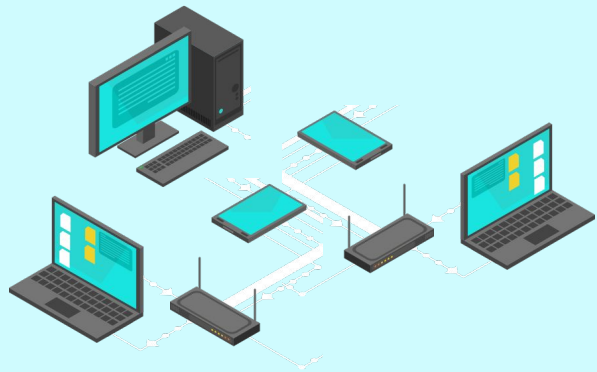


Introducing firewalld

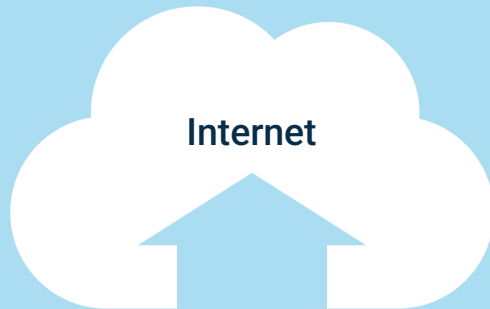
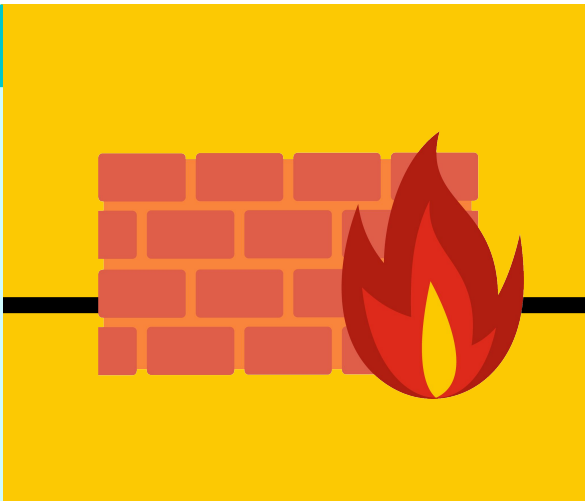
firewalld is a dynamically managed firewall that uses zones to divide network interfaces into groups that share a trust level. The zones are assigned sets of rules depending on the needs and restrictions of each zone's interfaces.

- Zones are the organization of rules. Each zone can contain several rules.
- **firewalld** can manage rule sets dynamically, without breaking existing sessions, disrupting services, and bringing down the entire network.

Inside (Trusted)

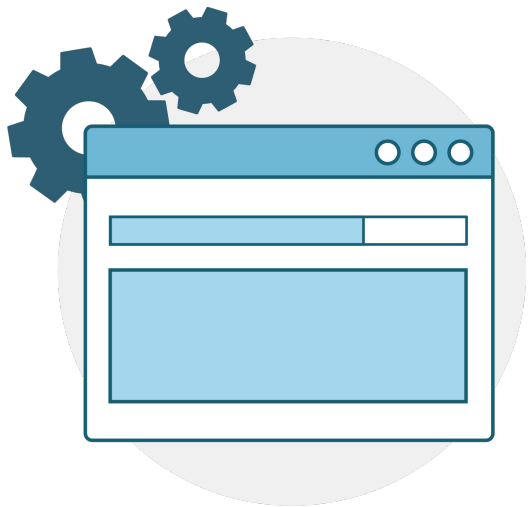


Outside (Not Trusted)



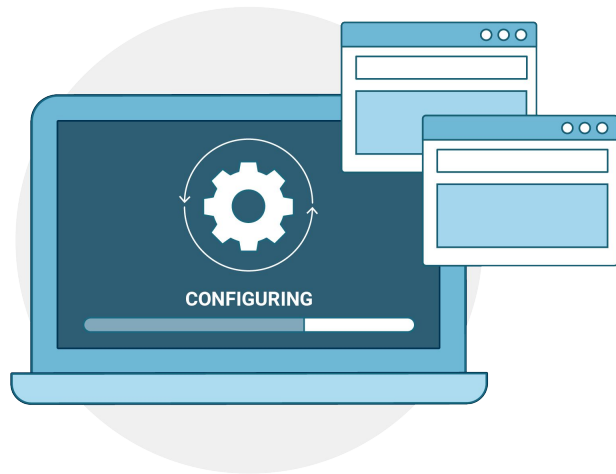
Runtime Configuration

- Valid until the next system reboot or service reload
- Used to test configurations



Permanent Configuration

- Loaded with each reboot and reload



firewalld and Services

`firewalld` also uses services to easily configure rules.

By designating which services you want to allow, `firewalld` automatically opens the ports associated with those services.

For example:

- If you enable the SSH service in a zone, it opens port 22 without requiring you to specify the port number explicitly.
- Services can be predefined, making it easy to configure the firewall rules most commonly required by most servers.





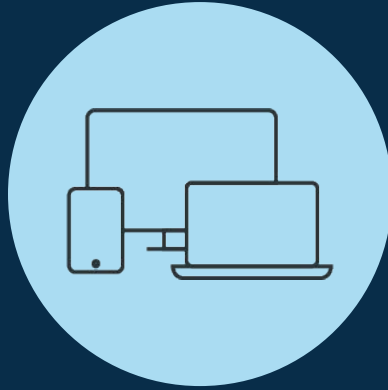
Demonstration Scenario

An IT administrator is bringing a new Microsoft AD server online. It will serve several new hosts on the third floor at the main office, which is serviced by the `eth1` on the firewall.

The administrator requested that this new network not be able to transmit or receive data from the Fifth Street office location, which uses an IP address of `10.10.0.10`.

The administrator asked you to **block** all ICMP pings as an extra level of protection.





Instructor Demonstration

`firewalld`

firewalld Commands

<code>sudo /etc/init.d/firewalld start</code>	starts firewalld
<code>sudo firewall-cmd --list-all-zones</code>	lists all current zones
<code>sudo firewall-cmd --zone=home --change-interface=eth0</code>	binds together interfaces
<code>sudo firewall-cmd --get-services</code>	lists currently configured services
<code>sudo firewall-cmd --zone=home --list-all</code>	lists all currently configured services for a specific zone
<code>sudo firewall-cmd --zone=home --add-rich-rule=</code>	adds specific rules to specific zones
<code>--add-icmp-block=echo-reply --add-icmp-block=echo-request</code>	blocks pings for specific zones



Activity

Configuring `firewalld`

In this activity, you'll continue to be an SOC analyst at Better Buys, Inc. You will be working with a server that is used to remotely administer other machines on the network using Telnet and SSH.

- You've been asked to update your firewall in order to implement different rules for different zones. Since this is challenging to do with UFW, you've decided to use `firewalld` to organize rules for your different zones.

Suggested Time
20 minutes



Time's Up!
Let's review



Questions?





Test Firewall Rules with Nmap

Nmap

Nmap is the industry-standard network scanner.

- Security professionals have the never-ending task of defending networks against attacks.
- They are also expected to know, at all times, what is running on their networks and any vulnerabilities that exist.
- Nothing beats the versatility and useability of Nmap, the industry standard in performing network scans.



Nmap

Attackers can get the following from network scans:

01

Name and version of operating system (OS fingerprinting)

02

All open and closed ports

03

All filtered ports (ports behind a firewall)

04

Types of services running on a specific port (service and daemon names)

05

Firewalking, which lets attackers perform network analysis to determine which Layer 4 protocols a specific firewall allows

Demonstration Scenario

In the demonstration, we'll perform Nmap scans against our UFW. Consider the following scenario:

01

Your security manager installs a new, fully-configured firewall and would like you to test it using Nmap.

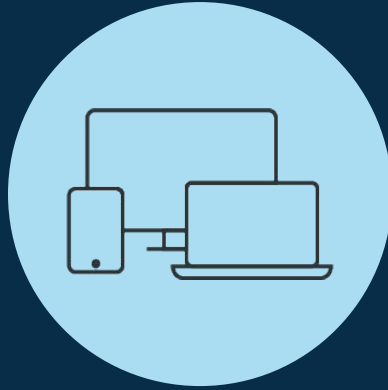
02

Use various fingerprinting techniques to reveal the type of operating system, services, daemons, and protocols that are running.

03

Test to see which ports are open, closed, and filtered.





Instructor Demonstration

Nmap

Nmap Commands

<code>nmap</code>	performs network scans
<code>nmap -sO</code>	performs an IP protocol scan
<code>nmap -sV</code>	enumerates a service type
<code>nmap -A -T4</code>	performs OS fingerprinting using fast execution
<code>uname -a</code>	prints the OS type and version
<code>nmap -sA</code>	enumerates the type of firewall in use
<code>nmap -sU -F</code>	performs a UDP fast scan



Activity

Test firewall rules with Nmap

In this activity, you'll continue in the role of an SOC analyst for Better Buys, Inc.

- Better Buys, Inc. has over 400 physical stores as well as a large online presence, which generates 60% of all sales.
- For Better Buys, Inc. to stay compliant with PCI DSS while ensuring a strong security posture, you've been tasked with conducting scans against your network to uncover potential vulnerabilities in your firewall or IDS (intrusion detection system).

Suggested Time
20 minutes



Time's Up!
Let's review



Questions?





Next Class

Intrusion detection, Snort, and network security monitoring



Thank You